

Inventory

Fixed assets

Depreciation

Loans

Retained earnings

Period close

Adjusting entries

Final accounting treatment should be validated during the financial-reporting sprint.

31\ Recommended Sprint Plan

Sprint 00 — Project Baseline and Architecture

Deliver:

Approved requirements

Roles and permissions

Lifecycle

Business rules

Architecture assumptions

Acceptance criteria

Initial backlog

Sprint 01 — Database Model and Accounting Foundation

Deliver:

Relational schema

Core entities

Relationships

Constraints

Versioning model

Accounting foundation

Sprint 02 — Authentication, Roles, and Permissions

Deliver:

Login

Role model

Record permissions

Field permissions

Commission visibility controls

Session rules

Sprint 03 — Tamper-Evident Audit Logging

Deliver:

Append-only audit model

Hash-chain design

Access logging

Restricted-access logging

Verification process

Sprint 04 — Customers, Contacts, Locations, and Projects

Deliver:

Customer records

Multiple contacts

Locations

Duplicate detection

Project code generation

Search

Sprint 05 — Master Sales Record

Deliver:

Master Sales Record form

Scope selections

Equipment

Serial numbers

Pricing

Costs

Payment options

Draft and approved versions

Sprint 06 — Controlled Lifecycle and Task Workflow

Deliver:

State machine

Approval tasks

Installation tasks

Three-day restriction

Scope-change process

Reopen and revision process

Sprint 07 — Document Generation and Artwork

Deliver:

Invoice generation

Contract population

Certificate population

Logo

State license artwork

Base64 validation

Artwork override process

Sprint 08 — Electronic Signatures and Reminders

Deliver:

Signature requests

Signing order

Authentication

Reminders

Expiration

Audit certificates

Signed PDFs

Sprint 09 — Payments, Receivables, Payables, and Adjustments

Deliver:

Cashier's check

Bank wire

Verification

Payment allocation

Credits

Refunds

Separate payables

Sprint 10 — Costs, Profitability, Commissions, and Contractor Reports

Deliver:

Cost rules

Gross Profit

Net Profit

Fixed compensation

Variable commissions

Commission adjustments

Biweekly reports

Annual summaries

Sprint 11 — Inventory, Assets, Loans, and Depreciation

Deliver:

FIFO inventory

Serial-number tracking

Fixed assets

Straight-line depreciation

Loans

Asset reports

Sprint 12 — Financial Ledger and Reporting

Deliver:

Double-entry ledger

Cash-basis reports

Balance sheet

Cash-flow statement

Statement of operations

Working Capital Requirement

Period close

Sprint 13 — Activity Dashboard and Search

Deliver:

Activity dashboard

Role-specific views

Filters

Exceptions

Project search

Commission visibility

Sprint 14 — Notifications, Email, and File Management

Deliver:

Notifications

Email delivery

Customer/project folders

Delivery audit records

Annual report email process

Sprint 15 — Testing, Security, and Data Integrity

Deliver:

End-to-end testing

Permission testing

Audit testing

Document consistency testing

Financial testing

Backup and restore testing

Sprint 16 — Deployment, Migration, and Operations

Deliver:

Deployment instructions

Initial-user setup

Data migration plan

Backup procedures

Recovery procedures

Administrator guide

User guides

Release checklist

32\ . Acceptance Criteria

The baseline is accepted when:

The Master Sales Record is the single source of truth.

Users cannot bypass required lifecycle steps.

Unauthorized users cannot view or edit restricted information.

Sales Associates see only their own commission data.

Approved records cannot be silently overwritten.

Revisions preserve previous versions.

Documents use consistent approved data.

State-specific artwork is automatically selected.

Artwork overrides require approval and a reason.

The three-day installation rule is enforced.

Projects cannot be complete before all required signatures and payment conditions are met.

Payments are linked to the correct project code.

Cashier's checks require bank confirmation.

Bank wires require a reference number or proof of receipt.

Variable commissions are withheld when profitability is zero or negative.

Commission adjustments are preserved and approved.

Financial periods can be closed and corrected through adjustments.

Audit entries are append-only and tamper-evident.

Restricted-access attempts are logged.

The activity dashboard shows current project status and required actions.

Reports are searchable and reproducible.

Customer/project files preserve all required documents and versions.

33\ Open Implementation Items

The following items require inputs or configuration during later sprints:

Existing contract PDF

Existing certificate PDF

Invoice layout and field placement

GECC logo artwork

State-specific license artwork

Exact document signature placement

Electronic-signature authentication method

Accounting chart of accounts

Asset useful lives by category

Vendor master list

Existing customer and project data

Email delivery configuration

User list and role assignments

Contractor payment-report formatting

Financial-report distribution list

Final accounting treatment of accounts payable and cash-basis reporting

34\. Known Risks

Existing PDFs may not be fillable or may require specialized PDF-overlay processing.

Electronic-signature requirements may require additional legal and technical validation.

Incorrect cost configuration could produce incorrect profitability and commission results.

Cashier's-check verification may remain manual until bank integration is implemented.

Financial reporting requires a carefully configured chart of accounts.

Existing spreadsheet data may contain duplicates or inconsistent values.

State license artwork may change and require version management.

Large audit logs may require archival and integrity-verification procedures.

35\. Merge Instructions

This bundle is the baseline project context.

When a later bundle is created:

Preserve this file unchanged.

Create the next bundle using the next sprint number.

Record all new decisions and changes.

If a later decision conflicts with this baseline, the later approved decision supersedes the earlier one.

Preserve the superseded requirement in the historical record.

Do not silently delete prior requirements.

Append bundles in sprint order to create the master file.

Master file name:

text

GECC-master-project-bundle.md

Recommended bundle order:

text

GECC-00-project-baseline.md

GECC-01-data-model.md

GECC-02-auth-and-permissions.md

GECC-03-audit-log.md

GECC-04-customers-and-projects.md

GECC-05-master-sales-record.md

GECC-06-workflow-state-machine.md

GECC-07-document-generation.md

GECC-08-electronic-signatures.md

GECC-09-payments-and-payables.md

GECC-10-costs-and-commissions.md

GECC-11-inventory-assets-and-loans.md

GECC-12-financial-reporting.md

GECC-13-dashboard-and-search.md

GECC-14-notifications-and-files.md

GECC-15-testing-and-integrity.md

GECC-16-deployment-and-operations.md

36\. Next Sprint

Sprint number: 01

Sprint name: Database Model and Accounting Foundation

Objective: Convert this approved baseline into a detailed relational database schema and accounting foundation.

Required inputs:

No additional business requirements required to begin

Existing documents may be deferred until Sprint 07

Expected deliverables:

Entity relationship model

Table definitions

Field definitions

Keys and relationships

Constraints

Versioning structure

Audit references

Initial accounting data model

Database acceptance tests

===== END FILE: GECC-00-Project-Baseline.md =====

=== BEGIN FILE: GECC-01-Data-Model.md ===

GECC-01-data-model.md

GECC Sales Back Office System — Sprint 01 Data Model and Accounting Foundation

Bundle Metadata

- Bundle name: GECC-01-data-model.md
- Project: GECC Sales Back Office System
- Company: Go Ecco Climate Control
- Company abbreviation: GECC
- Bundle type: Sprint 01 design and implementation bundle
- Status: Draft for Sprint 01 execution
- Created date: 2026-09-20
- Previous bundle: GECC-00-project-baseline.md
- Next planned bundle: GECC-02-auth-and-permissions.md
- Primary database: Robust searchable relational database

- System of record: Relational database
 - Google Sheets: Optional export or reporting destination only
 - Status: Sprint 01 design in progress
 - Database platform: PostgreSQL
 - Primary-key strategy: Numeric BIGINT identity keys
 - Business-entity identifier strategy: Numeric IDs
 - Business timezone: America/New_York
 - Effective dating: Non-overlapping effective-date ranges with version history
 - Entity retirement policy: Controlled retirement/deactivation for all entities; append-only preservation for historical and audit records
 - Audit retention: Permanent retention with partitioned searchable storage and immutable archival
 - Accounting minimum-table decision: Open
 - Financial calculated-value storage decision: Open
 - Historical calculation-snapshot decision: Open
- The approved baseline and Sprint 00 requirements remain unchanged.

1. Sprint Objective

Convert the approved GECC project baseline into a detailed relational database model and initial accounting foundation.

The Sprint 01 design must preserve all approved requirements from:

- GECC-00-project-baseline.md
- Sprint 00 decisions recorded in the preceding bundle

No Sprint 01 design may silently remove, weaken, or contradict an approved requirement.

2. Sprint 01 Deliverables

Sprint 01 must produce:

1. Entity relationship model
2. Table definitions
3. Field definitions
4. Primary keys and foreign keys
5. Unique constraints and indexes
6. Controlled enumerations
7. Required-field rules
8. Status-transition data structures
9. Master Sales Record versioning model
10. Document-version references
11. Approval and signature references
12. Payment and verification structures
13. Accounts receivable structures
14. Accounts payable structures
15. Cost and profitability data structures
16. Commission data structures

17. Financial-period structures
18. Initial accounting ledger model
19. Audit-reference fields
20. Database acceptance tests
21. Data-integrity and transaction rules
22. Migration and seed-data considerations

3. Authoritative Requirements Carried Forward

3.1 System of record

The relational database is the authoritative system of record.

PDFs, emails, exports, and Google Sheets are generated copies or outputs.

3.2 Master Sales Record

Each project must have an authoritative Master Sales Record.

The design must support:

- Master Sales Record ID
- Project association
- Customer association
- Version number
- Creation date and creator
- Assigned Sales Associate
- Retail price
- Payment option
- Scope
- Equipment
- Serial numbers
- Material costs
- Equipment costs
- Dealer fees
- Lead cost
- Technician cost
- Damon cost
- Jerry cost
- Contract data
- Invoice data
- Certificate data
- Approval status
- Document-version references
- Revision reason
- Revision timestamp
- Revising user

Approved versions must remain preserved.

3.3 Project identification code

The project identification code must:

- Use an automatically generated sequential number beginning at 101.
- Include Sales Associate initials.
- Include the Master Sales Record creation date.
- Use the format `Sequential Number-Sales Associate Initials-YYYY-MM-DD`.
- Prevent duplicates.
- Reserve the sequential number during creation.
- Prevent reuse of cancelled project codes.
- Preserve the original code through revisions.
- Warn about an active project at the same customer location.
- Require an explanation or correction before another active project at that location is allowed.

3.4 Versioning

The design must support:

- Immutable approved Master Sales Record versions.
- New versions for authorized reopening or scope changes.
- Immutable document versions.
- Revision user, date, time, and reason.
- Current and superseded version indicators.
- Preservation of original signatures and audit records.
- Links between revised records and their predecessors.

3.5 Audit references

Business records must be able to reference:

- Creation event
- Modification event
- Approval event
- Reopening event
- Revision event
- Related audit-log identifiers
- User responsible for the action
- Date and time of the action

The detailed tamper-evident audit implementation is planned for Sprint 03, but Sprint 01 must reserve the required relational references.

4. Core Entity Groups

Sprint 01 must model at least the following entity groups.

4.1 Identity and users

- User
- Role
- Permission

- User-role assignment
- User status
- Session reference placeholder

4.2 Customers and projects

- Customer
- Customer contact
- Project location
- Project
- Project assignment
- Project status history

4.3 Sales records

- Master Sales Record
- Master Sales Record version
- Scope selection
- Equipment
- Equipment serial number
- Cost component
- Pricing record
- Payment-option record

4.4 Documents

- Document
- Document version
- Document type
- Template version reference
- Artwork version reference
- Signature request reference
- Signature audit certificate reference

4.5 Workflow

- Workflow state
- State transition
- Task
- Task assignment
- Approval
- Exception
- Required action

4.6 Payments and receivables

- Payment
- Payment verification
- Payment proof
- Adjustment
- Credit
- Refund
- Accounts receivable balance or transaction structure

4.7 Payables and expenses

- Vendor
- Accounts payable
- Payable category
- Overhead expense
- Payable payment

4.8 Contractors and commissions

- Contractor or employee
- Commission configuration
- Commission calculation
- Commission earning event
- Commission report
- Commission report item
- Commission adjustment
- Annual commission summary

4.9 Inventory and assets

- Inventory item
- Inventory cost layer
- Inventory allocation
- Fixed asset
- Asset category
- Depreciation record
- Loan

4.10 Financial accounting

- Account
- Journal entry
- Journal entry line
- Cash receipt
- Cash disbursement
- Financial-report period
- Period lock
- Adjusting entry
- Retained earnings reference

4.11 Audit and configuration references

- Audit-event reference
- Configuration version
- State artwork reference
- Effective-date configuration

5. Required Relational Design Rules

The schema must use:

- Primary keys for every persistent entity.
- Foreign keys for all required relationships.
- Unique constraints for project codes and other required unique values.
- Check constraints or controlled lookup tables for enumerated statuses.
- Required-field constraints for mandatory data.
- Transactional saves for multi-table business operations.
- Indexes supporting approved search requirements.
- Explicit effective and retirement dates where configuration changes over time.
- Version identifiers for records requiring historical preservation.
- No hard deletion of approved, signed, paid, published, or audited records.
- Referential integrity for customer, project, document, payment, cost, and report relationships.

6. Required Database Acceptance Tests

Sprint 01 acceptance testing must demonstrate that:

- A project code cannot be duplicated.
- A project code sequence begins at 101.
- Cancelled project codes cannot be reused.
- A project retains its original code through Master Sales Record revisions.
- A Master Sales Record version can be preserved and superseded without being overwritten.
- A document version remains linked to the correct Master Sales Record version.
- A customer may have multiple contacts and projects.
- A project may have multiple equipment records and serial numbers.
- Accounts payable can be separated into equipment, dealer-fee, and materials categories.
- Payment records can be linked to the correct project and invoice.
- Payment verification status is distinct from payment entry status.
- Approved adjustments retain their original amount, adjusted amount, reason, approver, and timestamp.
- Commission records can be linked to projects, contractors, reports, and adjustments.
- Financial periods can be locked.
- Published-period corrections can be represented by adjustment records.
- Inventory serial numbers remain individually identifiable.
- FIFO inventory cost layers can be represented.
- Fixed assets can store straight-line depreciation inputs and outputs.
- Loans can store principal, interest, and payment information.
- Accounting journal entries can contain balanced debit and credit lines.
- Business records can reference future audit events.
- Required search fields can be indexed.
- Foreign-key and required-field violations are rejected.
- Multi-record saves either complete transactionally or roll back.

7. Sprint 01 Open Design Questions

These questions are for Sprint 01 architecture decisions and do not reopen the approved requirements interview:

1. Which relational database platform will be used?
2. What primary-key strategy will be used?
3. What timezone will govern timestamps and due dates?
4. Will audit references use a single event ID, multiple event IDs, or a related-event table?
5. Which statuses will use lookup tables versus database enumerations?
6. How will calculated financial amounts be stored for historical reproducibility?
7. What is the minimum chart of accounts required for the initial ledger?
8. How will accounting periods relate to calendar months and publication dates?
9. How will FIFO cost layers be allocated when inventory is partially issued?
10. How will record retirement be represented without deletion?
11. What indexing strategy will support dashboard filters and authorized search?
12. What migration staging tables are needed for existing spreadsheet data?

8. Sprint 01 Decision Log

No new Sprint 01 decisions have been approved yet.

Approved Sprint 00 decisions carried forward:

- Relational database is the system of record.
- Master Sales Record is the project source of truth.
- Approved records are immutable.
- Revisions create new versions.
- Workflow and status transitions must be enforced.
- Audit references must be reserved in the schema.
- Internal double-entry accounting is the approved architectural direction.
- Initial bank-payment verification is manual.
- Existing document templates may be deferred to Sprint 07.

9. Sprint 01 Completion Criteria

Sprint 01 is complete when:

- The entity relationship model is approved.
- All required baseline entities are represented.
- Required relationships and foreign keys are defined.
- Required fields and constraints are documented.
- Master Sales Record versioning is fully defined.
- Document and signature references are represented.
- Payment verification and adjustment structures are represented.
- Accounts receivable and accounts payable structures are represented.
- Inventory, fixed assets, loans, and depreciation structures are represented.
- Contractor commissions and reports are represented.
- Financial periods and locking are represented.
- The initial double-entry ledger structure is represented.
- Audit-reference fields are included.
- Required indexes are defined for approved searches and dashboard filters.
- Database acceptance tests are documented and executable.
- No approved baseline requirement is silently removed or contradicted.

- The model is ready for Sprint 02 authentication and permissions design.

10. Historical Record

Supersedes

None.

Preserves

- GECC-00-project-baseline.md
- Sprint 00 architecture deliverables
- Sprint 00 acceptance criteria
- Sprint 00 decisions
- Sprint 00 open questions and deferred implementation items

Changes introduced by this bundle

- Begins Sprint 01 schema and accounting-foundation planning.
- Converts the baseline entity list into a required data-model work plan.
- Defines database acceptance-test categories.
- Establishes Sprint 01 design questions without changing approved business requirements.

===== END FILE: GECC-01-Data-Model.md =====

=== BEGIN FILE: GECC-02-Auth-And-Permission.md ===

GECC-02-auth-and-permissions.md

GECC Sales Back Office System — Sprint 02 Authentication, Roles, and Permissions

Bundle Metadata

- Bundle name: GECC-02-auth-and-permissions.md
- Project: GECC Sales Back Office System
- Company: Go Ecco Climate Control
- Company abbreviation: GECC
- Bundle type: Sprint 02 design and implementation bundle
- Status: Approved design; ready for implementation
- Created date: 2026-09-20
- Previous bundle: GECC-01-data-model.md
- Next planned bundle: GECC-03-audit-log.md
- Database: PostgreSQL
- Primary-key strategy: Numeric BIGINT identity keys
- Business timezone: America/New_York
- System of record: PostgreSQL relational database

1. Sprint Objective

Implement the authentication and authorization foundation required to ensure that:

- Only authenticated users can access the system.

- Each user receives only the permissions appropriate to their role.
- Access can be restricted at the screen, record, field, and action levels.
- Sales Associates see only commission information for their own sales.
- Technicians see only assigned or authorized project information.
- Financial, payroll, commission, and audit information is restricted.
- Permission failures are logged.
- Authorization decisions are enforceable by the application and database access layer.

2. Sprint 02 Deliverables

Sprint 02 must produce:

1. Authentication design
2. User-account model
3. Role model
4. Permission model
5. Role-permission assignments
6. Record-level access scopes
7. Field-level access rules
8. Action-level authorization rules
9. Session-management design
10. Login and logout behavior
11. Failed-login handling
12. Account activation, deactivation, and lockout behavior
13. Permission-denial handling
14. Approval-separation rules
15. Commission-visibility controls
16. Financial-data access controls
17. Authorization test cases
18. Integration hooks for Sprint 03 audit logging

3. Authorization Model

GECC uses a combined authorization model consisting of:

1. Role-based access control
2. Record-scope access control
3. Field-level access control
4. Action-level access control

3.1 Role-based access control

RBAC determines the general capabilities granted to a user's role.

Examples:

- Sales Associates may create and update unapproved sales records.
- Sales Managers and Comptrollers may approve sales and financial records.
- Technicians may update installation completion data.

- Accounts Payable Associates may update authorized payable payments.

3.2 Record-scope access control

Record scope restricts which records a role may access.

Examples:

- A Sales Associate may access assigned customers and projects.
- A Technician may access assigned projects.
- An Other Contractor may access only specifically assigned projects and fields.
- A Sales Manager and Comptroller may access all business data.
- A Database Administrator may access authorized database functions but does not automatically receive approval rights.

3.3 Field-level access control

Certain fields require additional restrictions even when the surrounding record is visible.

Examples:

- Retail price
- Approved costs
- Commission amounts
- Payroll information
- Financial statement data
- Bank information
- Payment verification details
- Audit-log integrity fields

3.4 Action-level access control

The system must separately authorize actions such as:

- Create
- View
- Edit
- Approve
- Sign
- Reopen
- Generate
- Send
- Export
- Print
- Download
- Verify payment
- Enter overhead expense
- Approve adjustment
- Publish financial statement
- Lock financial period
- View audit log
- Export audit log

4. Authentication Requirements

The system must require authenticated login before access to protected functionality.

4.1 Required authentication behavior

The system must provide:

- Unique login identity for every user
- Account activation and deactivation
- Password or approved external authentication method
- Failed-login tracking
- Account lockout or equivalent protective response
- Session creation after successful authentication
- Session termination on logout
- Session expiration after an approved inactivity period
- Re-authentication for sensitive actions where required
- No shared user accounts
- No anonymous access to business records
- No authorization based only on hidden user-interface controls

4.2 Sensitive actions

The following actions require explicit permission checks at the point of action:

- Approving a Master Sales Record
- Approving retail price or costs
- Reopening an approved record
- Approving credits, refunds, or adjustments
- Signing an invoice or contract
- Signing a certificate as substitute Comptroller
- Approving commission changes
- Approving commission reports
- Publishing financial statements
- Locking a financial period
- Accessing the tamper-evident audit log
- Exporting restricted financial or commission information

5. Permission Data Model

5.1 `permission`

Field	Type	Requirement
id	BIGINT	Primary key
permission_code	VARCHAR(100)	Required, unique
resource_type	VARCHAR(80)	Required
action_code	VARCHAR(50)	Required
description	TEXT	Required

is_sensitive	BOOLEAN	Required
record_status	VARCHAR(30)	Required
is_active	BOOLEAN	Required
retired_at	TIMESTAMPTZ	Optional
retired_by	BIGINT	Optional foreign key
retirement_reason	TEXT	Optional

Example permission codes:

```
```text
customer.view
customer.create
customer.edit
project.view
project.create
project.edit
master_sales_record.approve
master_sales_record.reopen
invoice.sign
contract.sign
certificate.sign
payment.verify
adjustment.approve
commission.view_own
commission.view_all
commission_report.approve
financial_report.publish
financial_period.lock
audit_log.view
audit_log.export
```

## 5.2 role\_permission

Field	Type	Requirement
id	BIGINT	Primary key
role_id	BIGINT	Required foreign key
permission_id	BIGINT	Required foreign key
effective_from	DATE	Required
effective_to	DATE	Optional
granted_by	BIGINT	Required foreign key
grant_reason	TEXT	Required
record_status	VARCHAR(30)	Required
is_active	BOOLEAN	Required
retired_at	TIMESTAMPTZ	Optional
retired_by	BIGINT	Optional
retirement_reason	TEXT	Optional

Constraint:

text

UNIQUE(role\\_id, permission\\_id, effective\\_from)

## 5.3 record\_access\_scope

Field	Type	Requirement
id	BIGINT	Primary key

user_id	BIGINT	Required foreign key
resource_type	VARCHAR(80)	Required
resource_id	BIGINT	Required
scope_type	VARCHAR(40)	Assignment, ownership, authorization
effective_from	DATE	Required
effective_to	DATE	Optional
granted_by	BIGINT	Required foreign key
grant_reason	TEXT	Required
record_status	VARCHAR(30)	Required
is_active	BOOLEAN	Required
retired_at	TIMESTAMPTZ	Optional
retired_by	BIGINT	Optional
retirement_reason	TEXT	Optional

This table supports explicit access for assigned projects and contractors.

#### 5.4 field\_permission

Field	Type	Requirement
id	BIGINT	Primary key
role_id	BIGINT	Required foreign key
resource_type	VARCHAR(80)	Required
field_name	VARCHAR(120)	Required
can_view	BOOLEAN	Required
can_edit	BOOLEAN	Required
can_export	BOOLEAN	Required
effective_from	DATE	Required
effective_to	DATE	Optional
record_status	VARCHAR(30)	Required
is_active	BOOLEAN	Required

#### 5.5 user\_session

Field	Type	Requirement
id	BIGINT	Primary key
user_id	BIGINT	Required foreign key
session_identifier	VARCHAR(200)	Required, unique
created_at	TIMESTAMPTZ	Required
last_activity_at	TIMESTAMPTZ	Required
expires_at	TIMESTAMPTZ	Required
logout_at	TIMESTAMPTZ	Optional
termination_reason	VARCHAR(100)	Optional
session_status	VARCHAR(30)	Active, expired, logged_out, revoked
client_reference	TEXT	Optional

Session records are retained for audit integration.

#### 5.6 authentication\_event

Field	Type	Requirement
id	BIGINT	Primary key
user_id	BIGINT	Optional foreign key
login_identifier	VARCHAR(320)	Required
event_type	VARCHAR(40)	Login success, login failure, logout, lockout
occurred_at	TIMESTAMPTZ	Required
session_id	BIGINT	Optional foreign key
success_status	BOOLEAN	Required
failure_reason	VARCHAR(200)	Optional
source_reference	TEXT	Optional

## 6. Initial Roles

The system must support these roles:

Sales Associate  
Sales Manager  
Comptroller  
Installation Manager  
Technician  
Accounts Payable Associate  
Database Administrator  
Other Contractor

A user may have one or more roles, subject to effective dates and administrative approval.

One role may be designated the user's primary role.

## 7. Role Permission Matrix

Capability	Sales Associate		Sales Manager			Comptroller	Installation Manager			
	Technician	AP Associate	DBA							
Create customer	Yes	Yes	Yes	Authorized	scope	No	Authorized	scope	Authorized	
Create Master Sales Record			Yes	Yes	Yes	No	No	No	Authorized	
Edit unapproved sales record			Assigned records			Yes	Yes	Authorized	fields	No No
	Authorized									
Approve Master Sales Record			No	Yes	Yes	Per applicable workflow		No	No	No
View all business data	No		Yes	Yes	Authorized scope		No	Authorized scope		
	Authorized scope									
View own commission data			Yes	Yes	Yes	No	No	No	No	
View all commission data	No		Yes	Yes	No	No	No	No		
Edit approved retail price	No		Yes	Yes	No	No	No	No		
Edit approved costs		No	Yes	Yes	Authorized cost fields			No	No	No
Enter overhead expense	No		Yes	Yes	No	No	No	No		
Approve adjustment		No	Yes	Yes	No	No	No	No		
Sign contract	No	Yes	Yes	No	No	No	No			
Sign invoice	No	Yes	Yes	No	No	No	No			
Sign certificate	No	Substitute only			Substitute only		Yes	No	No	No
Schedule installation		No	Authorized exception			Authorized exception			Yes	No
	No	Authorized								
Update installation completion	No		No	Authorized		Authorized	Authorized	Assigned projects		
	No	Authorized								
Enter payment	No	Authorized	Authorized		No	No	Yes	Authorized		
Verify payment	No	Yes	Yes	No	No	No	Authorized only if assigned			
Approve commission report			No	Yes	Yes	No	No	No	No	
Publish financial statement			No	Yes	Yes	No	No	No	No	
View audit log	No	Yes	Yes	Yes	No	No	No			
Administer database functions			No	No	No	No	No	No	Yes	

"Authorized scope" means access is limited by record assignment, field permissions, and applicable workflow rules.

## 8. Role-Specific Record Access

### 8.1 Sales Associate

May access:

Customers they created or are assigned  
Projects assigned to them

Their own Master Sales Records  
Documents for their assigned projects  
Their own commission information  
Tasks assigned to them  
May not access:

Another Sales Associate's commission information  
Unassigned projects  
Restricted financial reports  
Audit-log contents  
Approved financial fields for editing  
8.2 Sales Manager and Comptroller  
May access:

All business records  
All projects and customers  
All commission and financial data  
All workflow exceptions  
Audit-log search and verification functions  
Approval authority remains distinct from ordinary view access.

8.3 Installation Manager  
May access:

Installation-related projects  
Assigned technicians and installation tasks  
Authorized installation cost fields  
Project change history  
Audit-log access  
May not:

Sign financial statements  
Approve financial statements  
Access unauthorized commission or payroll data  
8.4 Technician  
May access:

Assigned projects  
Approved scope of work  
Assigned installation tasks  
Required equipment and serial-number fields  
Completion notes  
Proposed scope-change fields  
Certificate review and sending functions  
May not access or modify:

Retail price  
Approved costs  
Contract terms  
Commission data  
Payroll data  
Financial reports  
8.5 Accounts Payable Associate

May access:

- Authorized vendors
- Authorized payable records
- Payment-status fields
- Payment dates and methods
- Related project information necessary for payable duties

#### 8.6 Database Administrator

May access:

- Authorized database administration functions
- Authorized search and maintenance functions
- Data-quality tools

The Database Administrator does not receive approval authority by default.

### 9. Field-Level Restrictions

#### 9.1 Financial fields

The following are restricted to Sales Manager, Comptroller, and authorized accounting users:

- Retail price after approval
- Equipment cost
- Material cost
- Dealer fee
- Lead cost
- Damon cost
- Jerry cost
- Technician cost
- Gross profit
- Net profit
- Profitability reports
- Balance-sheet data
- Cash-flow data
- Statement-of-operations data
- Accounts payable balances
- Accounts receivable balances

#### 9.2 Commission and payroll fields

Sales Associates may view only commission information related to their own sales.

Restricted fields include:

- Commission rates
- Contractor commission amounts
- Payroll-report totals
- Other Sales Associates' commission data
- Commission adjustments
- Annual commission summaries for other contractors

#### 9.3 Payment fields

Access to payment information must be limited according to role and duty.

Restricted fields include:

- Bank name
- Cashier's-check number

Wire reference number  
Uploaded proof of receipt  
Verification details  
Adjustment approval details  
9.4 Audit fields

Ordinary users must not edit or delete:

Hash values  
Previous-event references  
Event timestamps  
Original actor identity  
Integrity-verification results  
Audit-event content  
10. Authorization Enforcement

Authorization must be enforced at all applicable layers:

Application route or screen  
Service or business-operation layer  
Record-scope query  
Field read/write filtering  
Database transaction  
Export and download operation  
A hidden or disabled user-interface control is not sufficient protection.

Every permission failure must:

Deny the action.  
Avoid disclosing restricted data.  
Record the failed attempt.  
Include the user, role, resource, action, timestamp, session, and reason.  
Be available to authorized audit-log users.

#### 11. Approval Separation Rules

The authorization design must preserve these rules:

Sales Associates cannot approve their own sales.  
A user cannot approve an action they are not authorized to approve.  
Commission changes require Sales Manager approval.  
Early commission payment requires Sales Manager approval.  
Published financial statements require Sales Manager and Comptroller approval.  
The Installation Manager does not sign financial statements.  
The Comptroller signs a certificate only when the Installation Manager is unavailable.  
A Comptroller substitute certificate signature requires a recorded reason.  
Approval actions reference the exact record version being approved.  
A user may not approve an action that has been assigned to an incompatible role.  
Approval must be rejected if the record has been superseded or already approved by another valid version.

#### 12. Session and Account Rules

The implementation must support:

Active, inactive, locked, pending, and revoked account states  
Session creation on successful login  
Session expiration  
Manual session revocation

Logout  
Failed-login counting  
Lockout or equivalent protective handling  
Administrative account deactivation  
Prevention of access using expired or revoked sessions  
Recording of session identifiers with access events  
Exact timeout and lockout values remain configuration items pending approval.

### 13. Sprint 02 Decisions

#### D-02-001 — Authorization model

Use combined:

Role-based access control  
Record-scope access control  
Field-level access control  
Action-level access control

#### D-02-002 — Internal identifiers

Use numeric BIGINT identity IDs for users, roles, permissions, assignments, and access-scope records.

#### D-02-003 — Effective-dated permissions

Role assignments, role permissions, field permissions, and record scopes use effective dates and historical preservation.

#### D-02-004 — Default deny

If a permission is not explicitly granted or inherited from an active approved role assignment, access is denied.

#### D-02-005 — Database Administrator boundary

Database administration access does not automatically include approval, signing, commission, payroll, or financial-report authorization.

#### D-02-006 — Audit integration

Sprint 02 creates authentication and authorization event records and integration hooks.

Sprint 03 will implement the complete append-only tamper-evident audit log.

#### D-02-007 — Commission visibility

Sales Associates may view only commission information related to their own sales.

No role may bypass this restriction through search, export, report, or download functions unless separately authorized.

#### D-02-008 — Approval version binding

Approvals must reference the exact Master Sales Record, document, report, or financial-period version being approved.

### 14. Sprint 02 Acceptance Criteria

Sprint 02 is accepted when:

Unauthenticated users cannot access protected records or screens.

Each user has a unique identity.

Inactive or locked users cannot log in.

Failed logins are recorded.  
Logout terminates the active session.  
Session expiration is enforced.  
Every protected operation performs an authorization check.  
Sales Associates can see only their own commission data.  
Technicians can see only assigned or authorized projects.  
Other Contractors can see only explicitly assigned projects and fields.  
Database Administrators do not automatically receive approval permissions.  
Financial and payroll fields are hidden from unauthorized users.  
Unauthorized edits to approved records are rejected.  
Unauthorized exports and downloads are rejected.  
Permission failures are recorded for future audit-log implementation.  
Role assignments are effective-dated.  
Access scopes are effective-dated.  
Removing a role or assignment removes access after the effective time.  
Approval actions identify the user and exact record version.  
Certificate substitute signing requires a recorded reason.  
The system does not rely solely on front-end controls for security.  
A user cannot access a record outside the user's permitted scope.  
A user cannot access restricted values through alternate search or report paths.  
A revoked session cannot perform additional protected actions.  
A superseded version cannot receive a new approval.  
A user cannot approve an action that the user's role does not authorize.

## 15. Authorization Test Cases

### Authentication

Valid active user can log in.  
Invalid credentials are rejected.  
Inactive user cannot log in.  
Locked user cannot log in.  
Successful login creates a session.  
Logout terminates the session.  
Expired session cannot access protected records.  
Revoked session cannot execute protected actions.

### Sales Associate access

Sales Associate can view an assigned project.  
Sales Associate cannot view an unassigned project.  
Sales Associate can view their own commission.  
Sales Associate cannot view another Sales Associate's commission.  
Sales Associate cannot approve their own Master Sales Record.  
Sales Associate cannot edit an approved Master Sales Record.  
Sales Associate cannot export restricted financial data.

### Technician access

Technician can view an assigned project.  
Technician cannot view an unassigned project.  
Technician can update completion notes.  
Technician can update serial numbers where authorized.  
Technician cannot change retail price.  
Technician cannot change approved costs.  
Technician cannot view commission reports.  
Technician cannot approve financial reports.

### Manager and Comptroller access

Sales Manager can approve a Master Sales Record.  
Comptroller can approve a Master Sales Record.

Sales Manager can approve an adjustment.  
Comptroller can approve an adjustment.  
Sales Manager can sign an invoice.  
Comptroller can sign an invoice.  
Financial statement publication requires both required approvals.  
Comptroller substitute certificate signing requires a reason.  
Database Administrator access  
Database Administrator can use authorized administrative functions.  
Database Administrator cannot approve a sale by default.  
Database Administrator cannot approve commissions by default.  
Database Administrator cannot publish financial statements by default.  
Scope and field security  
Restricted fields are omitted or masked for unauthorized users.  
Restricted fields cannot be retrieved through alternate endpoints.  
Search results exclude unauthorized rows.  
Exports exclude unauthorized fields and records.  
Print and download functions enforce the same permissions as screen views.

#### 16. Sprint 02 Open Questions

These are implementation and configuration questions. They do not reopen the approved requirements baseline.

Will authentication use locally managed credentials, an external identity provider, or both?  
What password and multi-factor authentication policy will be adopted?  
What inactivity timeout is required?  
What maximum failed-login threshold should cause account lockout?  
Which users may grant or revoke role assignments?  
What approval is required for emergency access?  
What exact database row-level-security implementation will be used?  
Which fields require re-authentication before viewing or changing?  
What is the initial user list and role-assignment file?  
What notification should be sent after repeated permission failures?  
What session duration is appropriate for administrative users?  
Will access be granted through individual assignments, role inheritance, or both?  
What is the required process for temporary access?  
What is the required process for emergency access revocation?

#### 17. Sprint 03 Handoff

Sprint 03 must use the authentication and authorization events created by Sprint 02 to implement:

Append-only audit records  
Hash-chain references  
Access logging  
Restricted-access logging  
Permission-failure logging  
Integrity verification  
Audit-log search  
Audit-log export controls  
Audit-log retention and archival  
Sprint 03 must preserve the following event attributes:

User identity  
User role  
Date and time

Record or screen accessed  
Activity type  
Related record identifier  
Success or failure  
Session identifier  
Reason when required  
Previous audit-log entry reference  
Integrity hash or equivalent value  
18. Historical Record  
Supersedes  
None.

Preserves  
GECC-00-project-baseline.md  
GECC-01-data-model.md  
Sprint 00 decisions  
Sprint 01 decisions  
Approved role definitions  
Approved access restrictions  
Approved commission-visibility rules  
Approved audit requirements  
Changes introduced by this bundle  
Defines the Sprint 02 authentication and authorization model.  
Defines RBAC, record scope, field-level, and action-level authorization.  
Defines authentication and session data structures.  
Defines permission and access-scope data structures.  
Defines role-access behavior.  
Defines authorization acceptance tests.  
Establishes Sprint 03 audit-log integration requirements.  
===== END FILE: GECC-02-Auth-And-Permission.md =====  
=== BEGIN FILE: GECC-03-Audit-Log.md ===  
# GECC-03-audit-log.md

# GECC Sales Back Office System — Sprint 03 Tamper-Evident Audit Logging

## Bundle Metadata

- Bundle name: GECC-03-audit-log.md
- Project: GECC Sales Back Office System
- Company: Go Ecco Climate Control
- Company abbreviation: GECC
- Bundle type: Sprint 03 design and implementation bundle
- Status: Approved design; ready for implementation
- Created date: 2026-09-20
- Previous bundle: GECC-02-auth-and-permissions.md
- Next planned bundle: GECC-04-customers-and-projects.md
- Database: PostgreSQL
- Primary-key strategy: Numeric BIGINT identity keys
- Business timezone: America/New\_York
- Audit retention: Permanent
- Audit-log model: Append-only, chained, tamper-evident

---

## ## 1. Sprint Objective

Implement the tamper-evident audit-log foundation required to preserve a complete history of:

- User access
- Login and logout activity
- Searches
- Record views
- Record creation
- Record edits
- Approvals
- Reopenings
- Revisions
- Exports
- Prints
- Downloads
- Emails
- Signatures
- Payment activity
- Permission failures
- Restricted-access attempts
- Administrative changes
- Audit-log access
- Audit-integrity verification

The audit log must be separate from ordinary business records and protected from ordinary application edits and deletion.

---

## ## 2. Sprint 03 Deliverables

Sprint 03 must produce:

1. Append-only audit-event model
2. Audit-event database table
3. Hash-chain design
4. Audit-event canonicalization rules
5. Access-event logging
6. Restricted-access logging
7. Authentication-event integration
8. Permission-failure integration
9. Business-action logging
10. Administrative-change logging
11. Audit-log search design
12. Audit-log export design
13. Integrity-verification process
14. Archive and retention process
15. Audit-log access permissions
16. Audit-log monitoring and exception behavior
17. Audit-log acceptance tests
18. Sprint 04 integration handoff

---

### ## 3. Audit Principles

The audit system must follow these principles:

- Audit records are separate from ordinary business records.
- Audit events are append-only.
- Ordinary users cannot edit or delete audit events.
- Audit events remain permanently retained.
- Every event references the preceding event.
- An alteration, deletion, insertion, or reordering must cause integrity verification failure.
- Audit events record both successful and failed actions.
- Restricted-access attempts are logged even when access is denied.
- Audit-log access is itself audited.
- Audit exports are audited.
- Audit verification results are audited.
- Historical records remain searchable and reproducible.
- Audit timestamps use `America/New\_York` for business interpretation while preserving the actual event instant.

---

### ## 4. Audit Access Rules

Audit-log access is limited to:

- Sales Manager
- Comptroller
- Installation Manager

The following users do not receive audit-log access by default:

- Sales Associate
- Technician
- Accounts Payable Associate
- Other Contractor
- Database Administrator

The Database Administrator may maintain approved database infrastructure but may not automatically view business audit content through the application.

Audit-log permissions include:

```
```text
audit\_log.view
audit\_log.search
audit\_log.export
audit\_log.verify
audit\_log.view\_integrity\_failure
audit\_log.view\_archived
```

Audit-log access must be separately authorized from general database access.

5. Audit Event Data Model

5.1 audit_event

Field Type Requirement

id	BIGINT	Primary key
event_sequence_number	BIGINT	Required, unique
event_uuid	UUID	Required, unique event reference
occurred_at	TIMESTAMPTZ	Required
recorded_at	TIMESTAMPTZ	Required
user_id	BIGINT	Optional foreign key
user_role_snapshot	VARCHAR(100)	Required when user identified
session_id	BIGINT	Optional foreign key
event_type	VARCHAR(80)	Required
activity_type	VARCHAR(80)	Required
resource_type	VARCHAR(100)	Optional
resource_id	BIGINT	Optional
resource_business_key	VARCHAR(250)	Optional
related_project_id	BIGINT	Optional foreign key
related_customer_id	BIGINT	Optional foreign key
outcome	VARCHAR(30)	Success, failure, denied, error
failure_reason	TEXT	Required for failures where available
reason_text	TEXT	Required when business rules require a reason
request_reference	VARCHAR(200)	Optional
source_screen	VARCHAR(150)	Optional
source_operation	VARCHAR(150)	Optional
event_payload	JSONB	Required, canonicalized
previous_event_hash	VARCHAR(128)	Required except genesis event
event_hash	VARCHAR(128)	Required
hash_algorithm	VARCHAR(30)	Required
integrity_status	VARCHAR(30)	Valid, unverified, failed
archive_status	VARCHAR(30)	Hot, archived, restored
archive_segment_id	BIGINT	Optional
created_at	TIMESTAMPTZ	Required

5.2 Audit event sequence

event_sequence_number is assigned monotonically.

Requirements:

Sequence numbers cannot be reused.

Sequence numbers cannot be changed.

The next event references the hash of the immediately preceding event.

A missing sequence number is an integrity exception.

A duplicate sequence number is an integrity exception.

Out-of-order events are an integrity exception.

Concurrent transactions must serialize event-chain assignment safely.

5.3 Genesis event

The first event in the audit chain is a genesis event.

The genesis event contains:

Fixed sequence number

Fixed event type

Project identifier

Creation timestamp
Initial hash seed
Hash algorithm
System initialization metadata
The genesis event must be preserved permanently.

6. Hash-Chain Design

6.1 Hash algorithm

The initial implementation uses:

text

SHA-256

The hash_algorithm field must be stored with each event to support future algorithm migration.

6.2 Canonical event representation

The event hash is calculated from a canonical representation containing:

text

event_sequence_number
event_uuid
occurred_at
recorded_at
user_id
user_role_snapshot
session_id
event_type
activity_type
resource_type
resource_id
resource_business_key
related_project_id
related_customer_id
outcome
failure_reason
reason_text
request_reference
source_screen
source_operation
canonical_event_payload
previous_event_hash
Canonicalization requirements:

Fields are serialized in a fixed order.
Property names are normalized.
Null values are represented consistently.
Numeric values use fixed decimal formatting where applicable.
Timestamps use a consistent ISO-8601 representation.
Text encoding is UTF-8.
JSON object properties are sorted.

Arrays preserve their defined order.
Whitespace outside values is excluded.
The canonical payload is immutable after insertion.
6.3 Event-hash calculation
Conceptually:

text

```
event\_hash =  
SHA-256(  
    canonical\_event\_representation  
)
```

The hash must include the previous event hash.

This creates a chain:

text

Event 1 → Event 2 → Event 3 → Event 4
If Event 2 is modified, removed, inserted, or reordered, later chain verification must fail.

6.4 Concurrent event creation
Audit-event creation must use a serialized sequence-allocation mechanism.

The implementation must ensure that:

Two concurrent events cannot receive the same sequence number.
Each event references the actual previous event.
A failed business transaction does not leave an invalid chain entry.
An audit event for a committed business action is committed with the action.
A failed or denied action may be logged in its own successful audit transaction when the original transaction is rolled back.

7. Event Categories

7.1 Authentication events

Login success
Login failure
Logout
Session expiration
Session revocation
Account lockout
Account activation
Account deactivation
Password or authentication-factor change

7.2 Access events

Dashboard view
Database view
Customer-record view
Project-record view
Master Sales Record view
Document view
Financial-report view

Commission-report view
Administrative-configuration view
Search
Export
Print
Download
7.3 Business-record events
Customer created
Customer edited
Contact created
Contact edited
Project created
Project edited
Master Sales Record created
Master Sales Record saved as draft
Master Sales Record approved
Master Sales Record reopened
Master Sales Record revised
Equipment added
Serial number updated
Cost entered
Cost changed
Project status changed
Task created
Task completed
Project cancelled
Project completed
7.4 Document events
Document generated
Document regenerated
Document saved
Document printed
Document emailed
Document downloaded
Document sent for signature
Signature request created
Signature request reminded
Signature request expired
Document signed
Document superseded
Document cancelled
7.5 Payment and accounting events
Payment entered
Payment proof uploaded
Cashier's check verified
Bank wire verified
Payment rejected
Adjustment created
Adjustment approved
Refund approved
Credit approved
Accounts payable created
Payable payment entered

Financial period opened
Financial period published
Financial period locked
Adjustment entered into locked period
Journal entry posted
Journal entry reversed
7.6 Commission events
Commission calculated
Commission earned
Commission report created
Commission report approved
Commission report emailed
Commission adjustment created
Commission adjustment approved
Annual commission summary generated
Annual commission summary emailed
7.7 Security events
Permission granted
Permission revoked
Record scope granted
Record scope revoked
Permission failure
Restricted-access attempt
Unauthorized export attempt
Unauthorized download attempt
Administrative configuration changed
Audit verification started
Audit verification completed
Audit integrity failure detected

8. Event Payload Rules

The event payload must contain enough information to reconstruct what occurred without exposing unnecessary restricted data.

8.1 Permitted payload content

Examples:

Action performed
Prior status
New status
Record version
Approval reason
Revision reason
Adjustment reason
Signature role
Payment verification method
Document version
Artwork version
Permission evaluated
Authorization result
Search criteria category
Export type
Integrity-verification result

8.2 Restricted payload content

Sensitive data must be minimized.

The audit payload should not store:

Passwords

Authentication secrets

Session tokens

Private signing keys

Full payment credentials

Unnecessary personal information

Unnecessary document contents

Where a sensitive value must be referenced, store:

A masked value

A secure reference

A content hash

The related record identifier

8.3 Before-and-after values

For material changes, the event may store before-and-after values for approved fields.

Examples:

json

```
{  
  "field": "project\_status",  
  "before": "contract\_pending",  
  "after": "installation\_ready"  
}
```

For sensitive fields, store only:

Field name

Change indicator

Authorized reference

Hash of the prior and new values where necessary

9. Audit Logging Requirements by Operation

9.1 Reads and views

The system must log:

User

Role

Screen or resource

Record identifier where applicable

Timestamp

Success or failure

Session identifier

9.2 Searches

The system must log:

User

Role

Search operation

Search-resource type
Result count
Search timestamp
Whether restricted results were requested
Whether the search succeeded or failed
Search values should be minimized or masked where they contain personal information.

9.3 Creates and edits

The system must log:

Record type
Record identifier
User
Time
Operation
Version
Relevant changed fields
Result
Failure reason if applicable

9.4 Approvals

The system must log:

Approving user
Role
Exact record or document version
Approval type
Approval timestamp
Approval result
Approval reason where required
Related task or workflow state

9.5 Exports, prints, emails, and downloads

The system must log:

User
Resource type
Resource identifier
Output type
Recipient or destination where applicable
Timestamp
Success or failure
Applied authorization scope
File or document version

9.6 Permission failures

The system must log:

User identity if known
Requested resource
Requested action
Record identifier if known
User role
Session identifier
Failure reason
Timestamp

Request reference

10. Audit-Log Storage and Retention

Audit records are retained permanently.

10.1 Hot storage

Recent audit events remain in searchable PostgreSQL partitions.

Partitions should generally be organized by month using recorded_at.

Hot indexes must support:

Timestamp

User

Role

Event type

Activity type

Resource type

Resource ID

Project

Customer

Outcome

Session

Integrity status

10.2 Immutable archive

Older audit partitions may be moved to immutable archive storage.

Archive requirements:

Write-once or retention-locked storage

Permanent retention

Archive segment identifier

Segment start and end sequence numbers

Segment start and end hashes

Segment checksum

Export timestamp

Exporting process identifier

Verification status

Archiving must not change event content or sequence order.

10.3 Archive retrieval

Authorized users may request archived audit records.

Archive retrieval must:

Preserve original event content

Verify the archive segment

Verify chain continuity

Create an audit event for the retrieval

Restrict access according to Sprint 02 permissions

11. Integrity Verification

11.1 Verification scopes

The system must support verification of:

Entire audit chain
Date range
Sequence range
Archive segment
Resource-specific history
Project-specific history
User-specific history

11.2 Verification checks

The verification process must check:

Sequence continuity
Event-hash correctness
Previous-event-hash references
Genesis-event validity
Duplicate events
Missing events
Out-of-order events
Archive-segment boundaries
Archive checksums
Hash-algorithm compatibility
Canonical-payload consistency

11.3 Verification outcomes

Possible results:

Valid
Valid with archived segments
Incomplete
Failed
Unable to verify
Requires restoration

11.4 Integrity failure response

If verification fails:

Mark the affected event or segment as integrity_failure.
Create a high-priority administrative exception.
Notify Sales Manager, Comptroller, and Installation Manager.
Preserve the failed verification result.
Prevent silent repair or deletion.
Require documented investigation.
Record all investigation activity.
Preserve the original evidence.
Permit a separately authorized continuity or recovery process.
Do not rewrite historical audit events.

12. Audit Search Requirements

Authorized users must be able to search by:

Date range
User
Role
Session
Event type
Activity type
Resource type

Resource identifier
Project identification code
Customer
Outcome
Success or failure
Permission failure
Document version
Master Sales Record version
Payment
Commission report
Financial period
Integrity status
Archive status
Search results must display:

Event sequence number
Event timestamp
User
Role
Event type
Activity
Resource
Outcome
Integrity status
Archive status
Sensitive payload details require additional permission.

13. Audit Export Requirements

Authorized audit users may export audit records.

Exports must:

Apply the same access rules as search.
Include event sequence numbers.
Include event hashes.
Include previous-event hashes.
Include archive and integrity status.
Include export timestamp.
Include exporting user.
Include export criteria.
Include a content hash of the exported file.
Be recorded as audit events.
Preserve the original database records.
The export format should support:

CSV for structured review
JSON for machine processing
PDF or printable report for formal review
The final export format may be implemented in Sprint 14 if not completed earlier.

14. Database Protection Requirements

The audit-event table must be protected by:

Application-level denial of update and delete operations
Database permissions that deny ordinary application users update and delete access
Controlled insert access through an audit-writing function or service
Restricted direct database access
Trigger or procedure protection where appropriate
Separate audit schema or database role
Integrity-verification process
Backup and archive protection
The Database Administrator must not be able to alter audit history through ordinary application functions.

Database-level superuser access remains an operational risk requiring infrastructure controls, separation of duties, and administrative monitoring.

15. Audit-Event Write Behavior

Committed business operations

For a successful business operation:

Validate authorization.

Execute the business operation.

Generate the audit event.

Calculate the event hash.

Commit the business operation and audit event transactionally.

Failed or denied operations

For a denied or failed operation:

Reject or roll back the business operation.

Record the failure in a separate audit transaction.

Preserve the failure reason.

Associate the event with the session and request reference.

System failures

If audit-event creation fails during a required auditable business operation:

The business operation must fail closed unless an approved emergency mode exists.

The failure must be surfaced to the user.

The failure must create an operational alert.

No business operation may succeed silently without the required audit event.

16. Sprint 03 Decisions

D-03-001 — Audit model

Use a separate append-only audit-event store linked to business records by identifiers and references.

D-03-002 — Hash algorithm

Use SHA-256 for the initial audit-event hash chain.

D-03-003 — Hash-chain structure

Each event includes the hash of the immediately preceding event.

D-03-004 — Permanent retention

Audit records are retained permanently.

Older records may move to immutable archive storage but may not be routinely deleted.